

top secret!

There is a secret key to the internet, and if you got access to it, you could become a trillionaire overnight!

Robert Sovereign-Smith | robert@digit.in

When it comes to the internet, what do we need to know? You need to know that when you type in your bank site's URL, that you actually go to the correct URL, and don't end up at a phishing site. How this is done is that a certification authority (CA) issues all servers on the internet that use the HTTPS protocol with a certificate. Above these is a root-certificate, which is issued to a CA themselves, which in turn authenticates that they are who they say they are. All certificates signed by the CA inherit the trustworthiness of the CA itself, which means that it better be secure!

If someone were able to spoof a trusted CA, they would be able to point hundreds of millions of people like you to any server they wanted, and could give a hacker in a basement somewhere the ability to set up a server that will be indistinguishable from a bank's server to even trained internet users' eyes. Every single certificate issued by that CA would be compromised, without exception. This is why security for a CA's private key is a huge deal – like biometrics and seismic sensors and secure facilities with armed security type sensitive!

Let's take the DNSSEC root signing ceremony as an example, which was in the news for the wrong reasons recently. Long story short, one of the physical keys to a physical safe gave trouble, and a key signing ceremony had

to be postponed while a locksmith was brought in and the safe opened under the highest security protocols.

DNSSEC is responsible for making sure all root DNS servers across the globe have a trusted certificate. The root signing ceremony is a very high security affair, with multiple levels of authentication for each participant, including many ceremony protocols to be followed, and takes about two and a half hours to complete. It's also livestreamed so that there is complete transparency in the process (<https://digit.in/TopSecret>). The



ceremony has an administrator, a witness, two separate safe controllers, and at least 3 crypto officers from different countries. There are 14 total crypto officers around the globe at any given time, and there is a redundancy in terms of location – there are two locations where this signing happens. Thus, 7 crypto security officers are assigned to each location – one is in California, US, and the other in Virginia, US.

Each location has very high security, and multiple sensors to keep the two safes secure. These even include seismic sensors that can sense someone trying to blast a hole in the wall to get to the safe, or drill through the thick walls. Ac-

cess to the safes can only be done in the presence of the administrator and a witness, and that too after extensive biometric checks. Then people squeeze into the little safe room and the safes are unlocked. Inside Safe 2 (which only one person knows the combination to), are more safety boxes, which are locked and can only be opened with keys from the ceremony administrator and the crypto officer. Each box contains security cards that are used to unlock the hardware security module (HSM) that is contained in Safe 1. The cards are in tamper proof bags and plastic cases to ensure that they weren't opened since the last key signing ceremony.

A second operator unlocks Safe 1 which contains the HSM, which is the most important thing in that room. All anyone wants is access to this HSM to be able to bring the Internet to its knees (for a short time, at least). The HSM is connected to a specially built laptop that has no battery of any sort and is unable to store any information at all when unplugged. The laptop is booted with a DVD that is also kept in a tamper proof sealed bag, and also a secure USB that contains logs of previous access to the HSM. The laptop also cannot connect to any network of any sort, as it lacks the hardware to be able to do so.

Eventually, after many procedures and protocols are followed, the public keys are provided to the HSM, which signs them with the very secret private key it holds inside it, and generates many DNSKEY sets for use on the web by the root servers. After the ceremony is complete, all the stuff we mentioned happens in reverse, and everything is secured once again, and put back into tamper proof bags and there's loads of